Instituto Superior
de Engenharia
Politécnico de Coimbra

DEPARTAMENTO DE / DEPARTMENT OF
INFORMÁTICA E SISTEMAS

Licenciatura em Engenharia Informática

Ramo de Redes e Administração de Sistemas

Relatório de Projeto Autónomo

WPA2

Autor / Author

Rodrigo José Simões Gaudêncio

a2024133572@isec.pt

Grupo de Trabalho: **13**

Unidade Curricular:

Segurança

Ano Letivo:

2025/2026

Coimbra, junho 2026

INSTITUTO POLITÉCNICO
DE COIMBRA

INSTITUTO SUPERIOR
DE ENGENHARIA
DE COIMBRA

Índice

1 Introdução **1**

2 Proposta **3**

3 Protocolo WPA2 **5**

3.1 Enquadramento 5

3.2 Algoritmos de criptografia e integridade 5

3.2.1 Transição do TKIP para o CCMP 6

3.2.2 Estrutura e Funcionamento do CCMP 6

3.3 O Processo 4-Way Handshake 8

4 Demonstração Experimental **11**

4.1 Ambiente de testes 11

4.2 Monitorização e Reconhecimento da Rede 12

4.3 Captura do 4-Way Handshake 13

4.3.1 Validação da captura no Wireshark 15

4.4 Ataque de Dicionário (*offline*) 16

4.4.1 Preparação da *Wordlist* 16

4.4.2 Execução do ataque 18

5 Conclusão **21**

Referências **23**

Lista de Figuras

3.1 Código de Integridade da Mensagem [8] 7
3.2 Cifra da mensagem [8] 7
3.3 4-Way Handshake [4] 9

4.1 Ativação do *Monitor Mode* na interface *wlan0* 12
4.2 Parâmetros da rede alvo 13
4.3 Início do processo de captura do 4-Way Handshake 14
4.4 Ataque de desautenticação 14
4.5 Ataque de desautenticação 15
4.6 Tráfego Wireshark da captura *4wayhand-01.cap* 15
4.7 Extração da Wordlist - Passo 1 17
4.8 Extração da Wordlist - Passo 2 17
4.9 Descoberta da palavra-passe da rede 18

Acrónimos

WPA2 *Wi-Fi Protected Access 2*.

WPA *Wi-Fi Protected Access*.

WEP *Wired Equivalent Privacy*.

AES *Advanced Encryption Standard*.

RC4 *Rivest Cipher 4*.

CCMP *Counter Mode with Cipher Block Chaining Message Authentication Code Protocol*.

MIC *Message Integrity Check*.

TKIP *Temporal Key Integrity Protocol*.

AP *Access Point*.

PTK *Pairwise Transient Key*.

PMK *Pairwise Master Key*.

GTK *Group Transient Key*.

WPA2-PSK *Wi-Fi Protected Access 2 - Pre-Shared Key*.

VM *Virtual Machine*.

MAC *Media Access Control*.

BSSID *Basic Service Set Identifier*.

SSID *Service Set Identifier*.

PDU *Protocol Data Unit*.

EAPOL *Extensible Authentication Protocol over LAN*.

WPA3 *Wi-Fi Protected Access 3*.

Capítulo 1

Introdução

A internet surgiu no final da década de 1960 através de um projeto militar e académico, a ARPANET, sendo inicialmente baseada em infraestruturas físicas e ligações com fios [12]. Durante algumas décadas, esta manteve-se como a única forma de aceder à rede.

Com o avanço da tecnologia, surgiram as redes sem fios, suportadas pelas normas IEEE 802.11, que tinham como principal objetivo pôr fim à dependência de ligações físicas. Todavia, ao contrário das redes com fios, que exigem acesso físico ao meio de transmissão, nas redes sem fios qualquer dispositivo dentro da área de cobertura pode potencialmente intercetar as comunicações transmitidas [11].

Este problema levou ao desenvolvimento de mecanismos de proteção específicos para redes Wi-Fi. O projeto tem como objetivo analisar o funcionamento do protocolo *Wi-Fi Protected Access 2* (WPA2), compreender os seus mecanismos de segurança e avaliar a sua resistência a ataques através de um estudo experimental.

O presente relatório encontra-se organizado em cinco capítulos. O Capítulo 2, desenvolvido em primeiro, apresenta a proposta de projeto. O Capítulo 3 aborda os fundamentos teóricos do WPA2, incidindo sobre o protocolo *Counter Mode with Cipher Block Chaining Message Authentication Code Protocol* (CCMP) e o processo de autenticação baseado no 4-Way Handshake. No Capítulo 4 é descrita a componente experimental, incluindo

a monitorização da rede, a captura de tráfego e a realização de um ataque de dicionário *offline*. Por fim, o Capítulo 5 apresenta as conclusões obtidas e as recomendações de segurança resultantes do estudo realizado.

Capítulo 2

Proposta

Atualmente, o principal meio de acesso à Internet são as redes sem fios. Pelo que, todos nós utilizamos redes Wi-Fi diariamente. Ao refletir sobre isso, surgiu a curiosidade em compreender melhor que protocolos estão por trás das redes que utilizamos e como estes têm vindo a evoluir no sentido de proporcionar uma maior segurança aos seus utilizadores. Depois de analisar alguns dos temas possíveis dentro da segurança em redes, foi escolhido o tema "Segurança em Redes Wi-Fi: WPA2, WPA3 e 802.11w".

Este tema enquadra-se na unidade curricular de Segurança, pois aborda mecanismos de proteção ativa aplicados a redes e complementa os conteúdos da UC relacionados com autenticação, controlo de acesso e mitigação de ataques.

Do ponto de vista experimental, o projeto será desenvolvido com recurso a um router com suporte a WPA2 e WPA3, bem como a ferramentas de análise de tráfego como o Wireshark. Será ainda utilizada a ferramenta airmon-ng para colocar a interface wireless em modo monitor, permitindo a captura e análise de handshakes. Até ao momento, foram realizadas experiências iniciais. Nomeadamente, a captura de tráfego durante o processo de associação a uma rede WPA2. Estes testes permitiram confirmar que o ambiente de trabalho necessário para desenvolver o projeto está funcional.

Capítulo 3

Protocolo WPA2

3.1 Enquadramento

O protocolo WPA2 surgiu para dar resposta aos problemas de segurança encontrados no protocolo *Wired Equivalent Privacy* (WEP).

Antes do WPA2, o *Wi-Fi Protected Access* (WPA) tentou corrigir parte destas vulnerabilidades. No entanto, esta tentativa resultou numa solução temporária que veio a ser formalizada pelo WPA2 em 2004 [10].

3.2 Algoritmos de criptografia e integridade

O WPA2 introduziu melhorias significativas nos algoritmos de criptografia face aos seus antecessores, tendo substituído o algoritmo *Rivest Cipher 4* (RC4), utilizado em WPA e WEP, pelo *Advanced Encryption Standard* (AES). Ao contrário do RC4, que é uma cifra de fluxo, o AES utiliza uma cifra de bloco, muito mais resistente a ataques de força bruta. Além disso, o WPA2 utiliza chaves simétricas (iguais) para o processo de cifra e decifra, o que garante a integridade dos dados através do protocolo CCMP [5].

O CCMP resolve duas falhas críticas dos protocolos WPA e WEP, no âmbito de dois pilares da segurança da informação:

- *Confidencialidade*: Utiliza o AES para garantir que os dados não sejam lidos por terceiros [6].

- *Integridade*: Utiliza o *Message Integrity Check* (MIC) para garantir que o conteúdo do pacote não foi alterado durante a transmissão [1].

3.2.1 Transição do TKIP para o CCMP

Antes da implementação definitiva do WPA2, o protocolo WPA utilizou o *Temporal Key Integrity Protocol* (TKIP) como uma solução de curto prazo. O TKIP foi desenvolvido com o objetivo de melhorar a criptografia presente no WEP, sem a necessidade de investir num equipamento novo. Esta implementação foi realizada a partir de atualizações de software, no entanto, manteve o algoritmo RC4 [2].

Com o surgimento do WPA2 e através da norma 802.11i, o TKIP foi substituído pelo CCMP, que utiliza o algoritmo de criptografia AES [5]. Esta mudança permitiu abandonar um algoritmo facilmente quebrável que, por utilizar padrões para os primeiros bytes da sua sequência, permitia aos atacantes adivinhar a chave sem a necessidade de testar todas as combinações possíveis [9].

3.2.2 Estrutura e Funcionamento do CCMP

Através de um processo de encapsulamento rigoroso, o protocolo CCMP assegura a confidencialidade, integridade e autenticidade dos pacotes transmitidos. O diagrama presente na figura 3.1 permite visualizar o processo responsável pela geração do MIC.

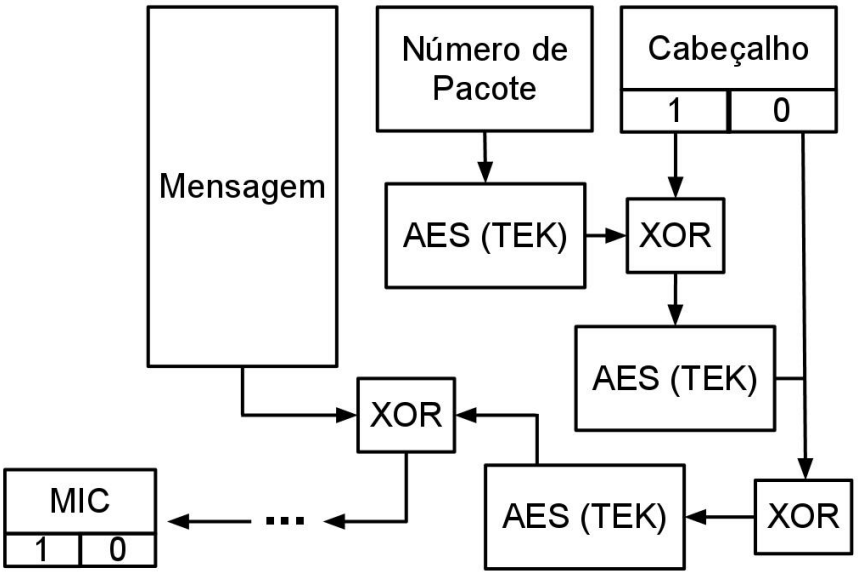


Figura 3.1: Código de Integridade da Mensagem [8]

Por outro lado, o diagrama da figura 3.2 representa o processo de cifra da mensagem.

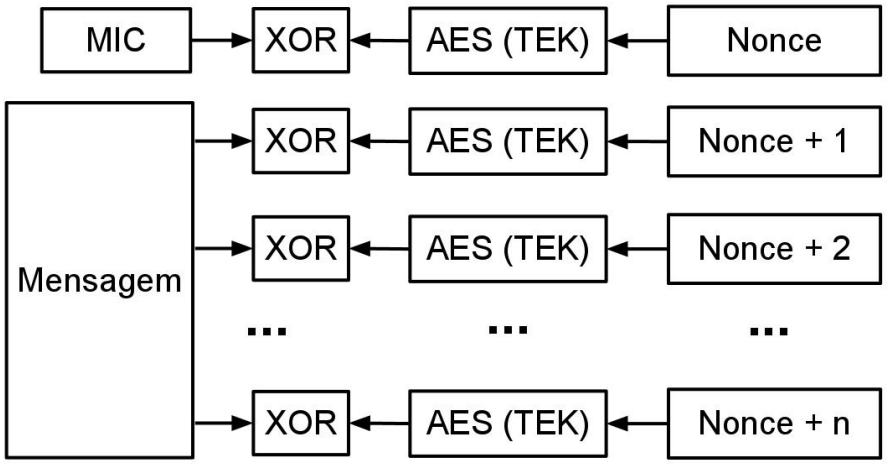


Figura 3.2: Cifra da mensagem [8]

Nota: *Optou-se por não aprofundar a explicação detalhada destes diagramas, por exceder o âmbito deste projeto. Assim, as figuras 3.1 e 3.2 servem apenas para contextualizar os processos referidos.*

O CCMP utiliza uma chave secreta, partilhada entre o recetor e o emissor da mensagem. Através desta chave, o emissor cifra a mensagem e gera o MIC. Por sua vez, o recetor, através da mesma chave, decifra o conteúdo e volta a calcular o MIC. Se o MIC calculado pelo recetor coincidir com o MIC recebido, confirma-se que a mensagem não foi alterada durante a transmissão. Este mecanismo garante que, depois de estabelecida a ligação, as comunicações permaneçam seguras contra interceções ou modificações por parte de terceiros [7].

3.3 O Processo 4-Way Handshake

Tanto o cliente como o *Access Point* (AP) precisam de saber a palavra-passe correta da rede, sem que esta seja "transmitida pelo ar". Utiliza-se, para essa finalidade, o *4 Way-Handshake*.

Este processo é responsável pela derivação das chaves temporárias que serão utilizadas pelo protocolo CCMP, referido em 3.2.2, para cifrar os dados transmitidos. A figura 3.3 ilustra as mensagens trocadas, que funcionam da seguinte forma [7]:

- *Mensagem 1*: O cliente recebe um *ANonce* do AP, gerado aleatoriamente pelo emissor, e deriva a *Pairwise Transient Key* (PTK) através do valor recebido e da palavra-passe da rede, gerando o MIC.
- *Mensagem 2*: O cliente gera o seu próprio valor aleatório (*SNonce*) e envia-o, juntamente com um MIC, ao AP. Por sua vez, o AP gera o seu próprio MIC e compara-o com o recebido para confirmar que o cliente possui a palavra-passe correta.
- *Mensagem 3*: O AP envia o pedido de instalação das chaves, o MIC e a *Group Transient Key* (GTK). Se o MIC recebido pelo cliente for igual ao calculado pelo mesmo, então confirma-se que, tanto o AP quanto o cliente, possuem a mesma *Pairwise Master Key* (PMK).
- *Mensagem 4*: O cliente instala a PTK e a GTK e envia uma mensagem com o MIC gerado por si, para confirmar a instalação das chaves.

O AP recebe esta mensagem e compara os diferentes MIC. Se estes coincidirem, instala a PTK e está pronto para iniciar a comunicação cifrada por CCMP.

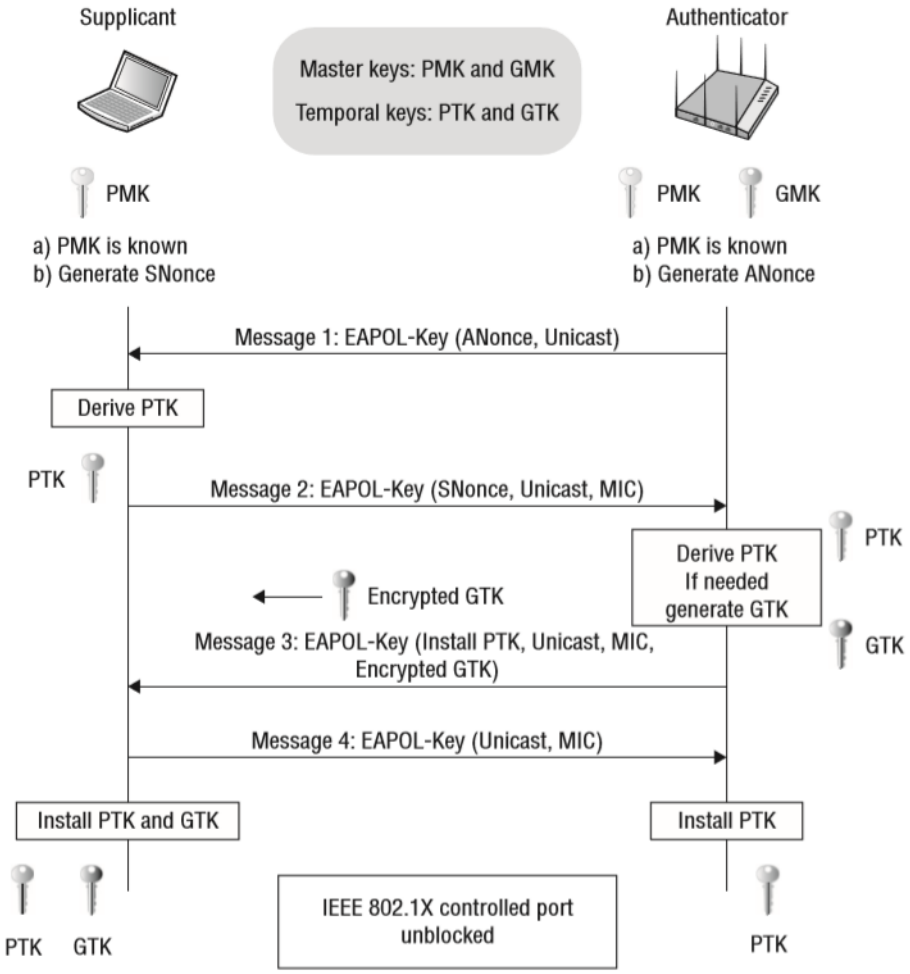


Figura 3.3: 4-Way Handshake [4]

A captura bem-sucedida da *Mensagem 1* e da *Mensagem 2* permite executar um ataque de dicionário, em que o atacante tenta gerar um MIC que corresponda ao capturado na *Mensagem 2* [3].

Capítulo 4

Demonstração Experimental

Este capítulo tem como principal objetivo demonstrar, de forma prática, as fragilidades do protocolo WPA2 referidas no capítulo anterior. A demonstração foca-se na captura do tráfego de autenticação, utilizado para descobrir a senha da rede através de um ataque de dicionário.

4.1 Ambiente de testes

Para evitar interferir em redes externas e garantir o cumprimento das normas éticas, o ataque foi realizado num ambiente controlado e montado para este efeito. O ambiente foi composto pelos seguintes elementos:

- *Ponto de Acesso (AP)*: Repetidor de sinal, configurado para estender uma rede pessoal. O dispositivo utiliza o protocolo *Wi-Fi Protected Access 2 - Pre-Shared Key* (WPA2-PSK) e o algoritmo de cifra CCMP(AES).
- *Cliente*: Desktop com ligação estabelecida ao AP.
- *Estação de Ataque*: *Virtual Machine* (VM) com a distribuição *Kali Linux* (versão 2026.1), executada no *hipervisor VirtualBox*. A utilização deste sistema operativo permitiu a execução das ferramentas da *suite aircrack-ng* num ambiente otimizado para auditorias de segurança.

- *Interface de Rede (Monitor Mode)*: Placa de rede com ligação direta à VM. Esta placa utiliza o *chipset* RTL8821AU, que a torna capaz de injetar pacotes e operar em *Monitor Mode*.
- *Interface de Rede (Ligação ao AP)*: Placa de rede do computador, responsável por aceder ao AP e sem nenhuma funcionalidade além dessa.

4.2 Monitorização e Reconhecimento da Rede

Ao contrário do modo por omissão (*Managed*), em que a placa de rede só processa pacotes destinados ao seu próprio endereço *Media Access Control* (MAC), o *Monitor Mode* permite que a mesma capture todo o tráfego que circula no canal sem se conectar a uma rede. Antes de ativar este modo, executou-se o comando *airmon-ng check kill* que interrompeu o *Network Manager* e encerrou processos em conflito. Por fim, o comando *iwconfig* permitiu consultar a interface ativa (*wlan0*), utilizada como argumento no comando *airmon-ng start wlan0* para iniciar a monitorização. Na Figura 4.1 é possível ver este processo por completo.

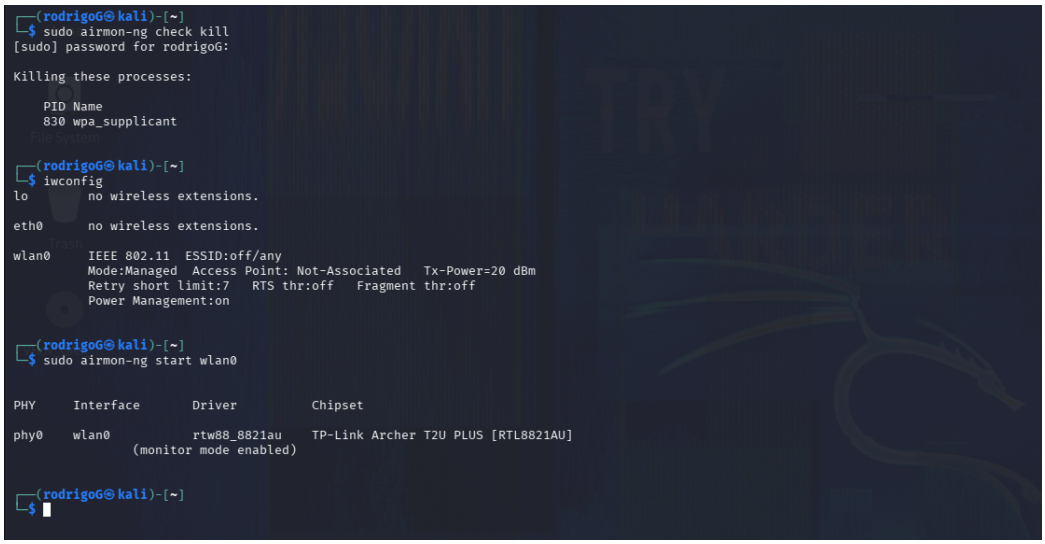


Figura 4.1: Ativação do *Monitor Mode* na interface *wlan0*

Com a interface em modo monitor, procedeu-se ao reconhecimento das redes circundantes. O comando *airodump-ng wlan0* permitiu descobrir os parâmetros da rede alvo (SEC-PROJ-WPA2-G13), nomeadamente o *Basic Service Set Identifier* (BSSID) e o canal de operação (*CH*). A Figura 4.2 apresenta a lista de redes detetadas, onde apenas a rede em estudo se encontra visível por questões de privacidade.

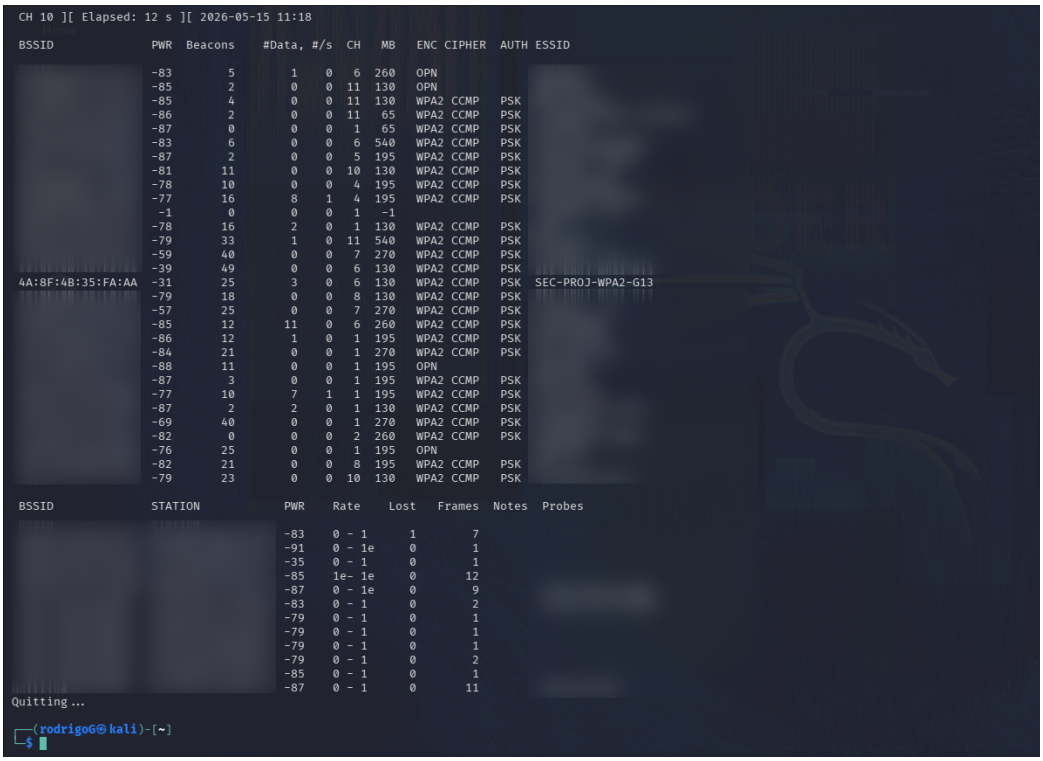


Figura 4.2: Parâmetros da rede alvo

4.3 Captura do 4-Way Handshake

Identificados os parâmetros do alvo, iniciou-se a captura do tráfego de autenticação, processo ilustrado na Figura 4.3. Utilizou-se o comando *airodump-ng -c 6 –bssid 4A:8F:4B:35:FA:AA -w 4wayhand wlan0*, de modo a direcionar a escuta (através da interface *wlan0*) exclusivamente para a rede em estudo (argumentos *–bssid* e *-c*) e armazenar os pacotes num ficheiro de extensão *.cap* e prefixo *4wayhand* (argumento -w).



Figura 4.3: Início do processo de captura do 4-Way Handshake

Dado que este processo (*4-Way Handshake*) ocorre apenas no momento em que um cliente estabelece uma ligação ao AP, utilizou-se o comando *aireplay-ng –deauth 00 -a 4A:8F:4B:35:FA:AA wlan0* para forçar a reautenticação do dispositivo ligado (Figura 4.4). O argumento *–deauth 0* permitiu executar o ataque em modo contínuo, enquanto o argumento *-a* garantiu que o envio de *frames* de desautenticação fosse direcionado apenas ao BSSID indicado. O ataque foi executado numa consola dedicada.

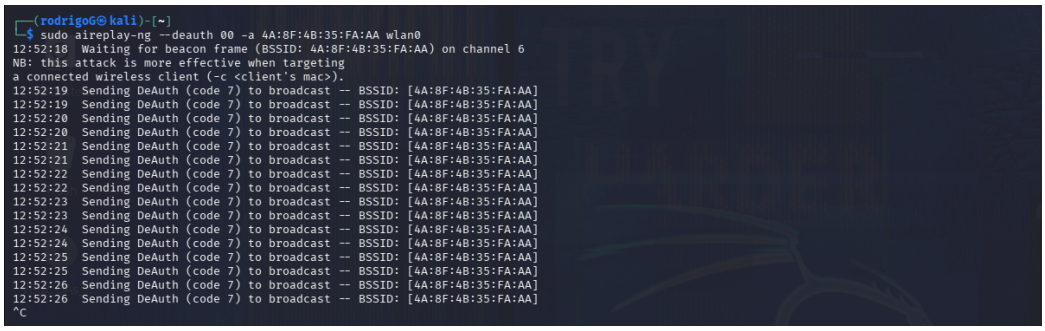


Figura 4.4: Ataque de desautenticação

Assim que o *airodump-ng* confirmou a interceção do processo de autenticação, o ataque foi interrompido através da sequência de teclas *CTRL + C* (Figura 4.4), resultando na captura do *WPA handshake* presente na Figura 4.5.



Figura 4.5: Ataque de desautenticação

4.3.1 Validação da captura no Wireshark

Analisou-se, através do *Wireshark*, o ficheiro de extensão *.cap* criado pelo *airodump-ng* (Figura 4.3).

Para isolar o tráfego de interesse, aplicou-se o filtro de visualização *eapol*, que eliminou as *Protocol Data Unit* (PDU) irrelevantes para esta análise (como *Beacons* ou *Probe Responses*), o resultado deste filtro encontra-se na Figura 4.6. O protocolo *Extensible Authentication Protocol over LAN* (EAPOL) é responsável pelo transporte das chaves criptográficas durante o estabelecimento de ligação entre o cliente e o AP.

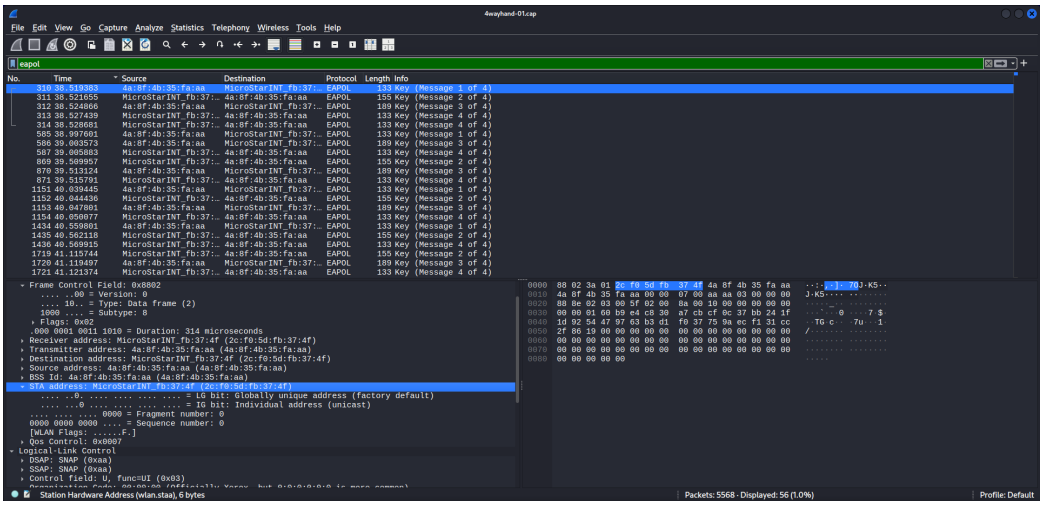


Figura 4.6: Tráfego Wireshark da captura *4wayhand-01.cap*

A captura (Figura 4.6) apresenta múltiplas instâncias de mensagens do tipo *Message x of 4*, algumas delas repetidas ou fora de sequência. Tal deve-se ao ataque de desautenticação (Figura 4.4), que, ao forçar o cliente a desconectar-se, desencadeou várias tentativas de reautenticação. No entanto, a presença de conjuntos completos das quatro mensagens do *4-Way Handshake* assegura a integridade dos dados necessários à etapa seguinte.

Confirmou-se, assim, o fluxo teórico de mensagens referido no Capítulo 3.3, que ocorre entre o AP (endereço MAC *4A:8F:4B:35:FA:AA*) e o cliente (endereço MAC *2C:F0:5D:FB:37:4F*, destacado na Figura 4.6).

4.4 Ataque de Dicionário (*offline*)

Confirmada a integridade dos dados de autenticação, prosseguiu-se para a fase final desta experiência. Esta etapa é executada de forma totalmente *offline*, o que significa que o sucesso do ataque depende exclusivamente do dicionário de palavras (*wordlist*) utilizado e da capacidade computacional disponível, prescindindo de qualquer interação, transmissão ou proximidade física com o AP.

4.4.1 Preparação da *Wordlist*

Antes de iniciar o ataque, foi necessário extrair a *wordlist RockYou.txt*, que serviria de base para o mesmo. Esta lista contém milhões de palavras-passe reais obtidas a partir de fugas de informação e é usada por padrão neste tipo de testes. Como o ficheiro ocupa um espaço considerável, o *Kali Linux* disponibiliza-a no formato comprimido *.gz*, sendo necessário descompactá-la antes de a utilizar no programa de *cracking*.

Começou-se por abrir o *Menu de Aplicações* e selecionar, dentro da categoria *08 - Credential Access* e secção *Password Profiling & Wordlists*, a opção *wordlists* (Figura 4.7).

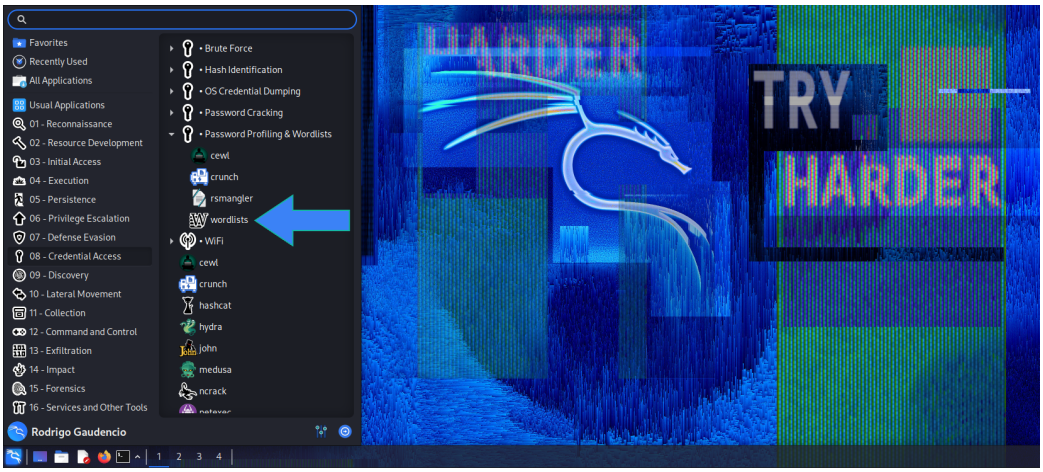


Figura 4.7: Extração da Wordlist - Passo 1

De seguida, através da janela de terminal aberta automaticamente, confirmou-se a extração desta lista de palavras. Verificou-se, ainda, a sua presença na pasta das *wordlists*, através do gestor de ficheiros *Thunar* (Figura 4.8).

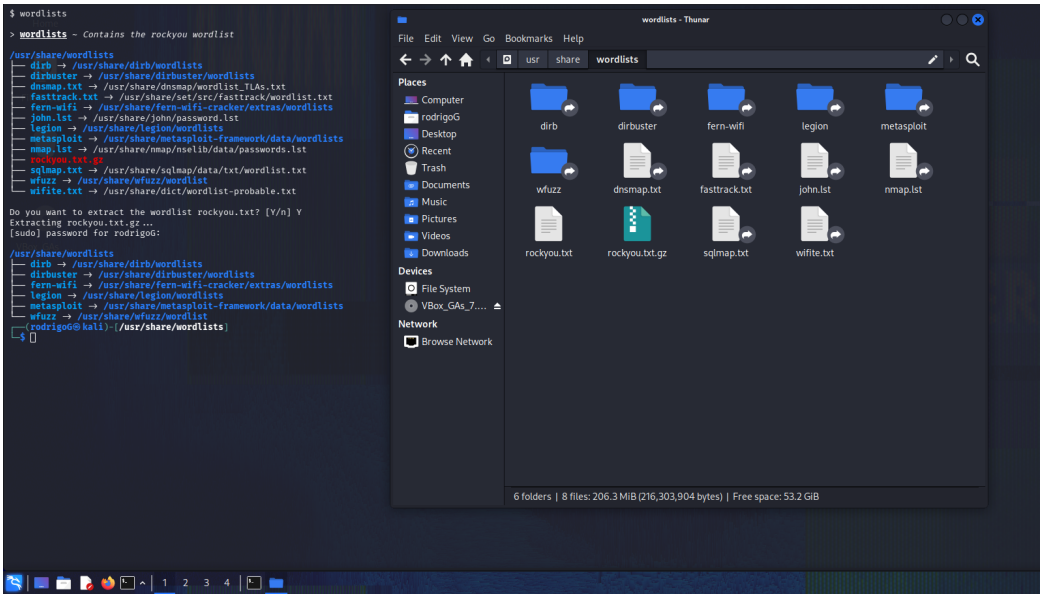


Figura 4.8: Extração da Wordlist - Passo 2

4.4.2 Execução do ataque

Com a *wordlist* descompactada e o ficheiro de captura pronto, avançou-se para a fase de quebra da cifra. Executou-se o comando *aircrack-ng -w /usr/share/wordlists/rockyou.txt 4wayhand-01.cap* no terminal.

O *Aircrack-ng* realiza um ataque de dicionário *offline*. Para tal, analisa o ficheiro de captura e extrai os parâmetros necessários do *4-Way Handshake*, nomeadamente os *nonces*, os endereços MAC das entidades envolvidas (BSSID do ponto de acesso e MAC da estação cliente), o MIC de uma das mensagens trocadas e o *Service Set Identifier* (SSID) da rede. De seguida, testa sequencialmente as palavras presentes na *wordlist*, utilizando cada uma delas como palavra-passe candidata. Para cada candidato, é gerada a PMK a partir da palavra-passe e do SSID da rede. A partir da PMK, são derivados os restantes parâmetros criptográficos necessários para obter a PTK. Por fim, é recalculado o MIC da mensagem capturada, que é comparado com o MIC presente no *4-Way Handshake*. Quando ocorre uma correspondência exata, a ferramenta interrompe o processo e apresenta a palavra-passe correta no ecrã (Figura 4.9).

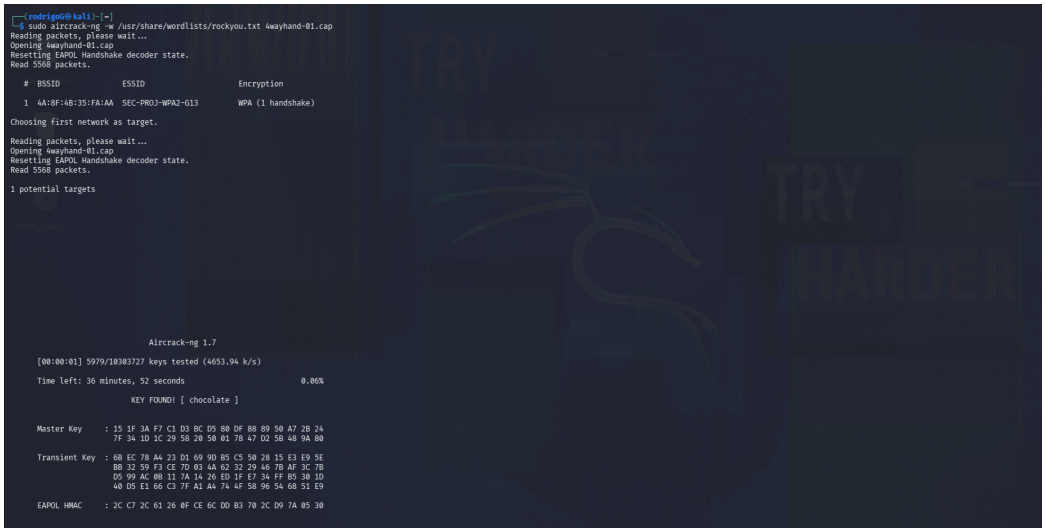


Figura 4.9: Descoberta da palavra-passe da rede

Como se pode observar na Figura 4.9, o ataque foi bem sucedido. A ferramenta utilizada demorou apenas 1 segundo para encontrar a palavra-passe correta (chocolate) e processou um total de 5979 chaves candidatas nesse curto período. O sucesso desta etapa demonstra o impacto prático de utilizar credenciais fracas, baseadas em termos simples do dicionário e sem caracteres complexos.

Capítulo 5

Conclusão

O estudo experimental desenvolvido neste projeto permitiu analisar, na prática, o funcionamento das redes sem fios e as fragilidades do protocolo WPA2. Embora a teoria aponte o protocolo CCMP (com cifra AES) como uma boa solução para garantir a confidencialidade dos dados, as experiências realizadas demonstraram que a segurança da rede pode ser comprometida se o processo de autenticação inicial for intercetado.

A análise de tráfego realizada no *Wireshark*, com base no ficheiro de captura *4wayhand-01.cap* (renomeada para *SEC-2526-Grp13-Proj-Cap04-01.pcapng*), foi fundamental para compreender esta vulnerabilidade. Ao isolar as mensagens EAPOL, verificou-se que um atacante não precisa de estar associado à rede para obter a informação criptográfica essencial. Além disso, o envio de pacotes de desautenticação permitiu forçar a reautenticação do cliente, de forma a expor o *4-Way Handshake*, incluindo os *nonces* e o MIC, no meio de transmissão.

Com o *handshake* capturado, o ataque de dicionário *offline* realizado com o *Aircrack-ng* demonstrou que a segurança do WPA2 depende, na prática, da complexidade da palavra-passe escolhida pelo utilizador. O facto de a ferramenta ter recuperado a palavra-passe *chocolate* em apenas um segundo, após testar 5979 candidatas, evidencia que a segurança do protocolo se torna ineficaz quando são utilizadas credenciais simples ou presentes em listas públicas como a *RockYou.txt*.

Conclui-se que o WPA2, isoladamente, já não oferece garantias de segurança suficientes face à capacidade computacional atual. Para mitigar o vetor de ataque explorado, recomenda-se a adoção do *Wi-Fi Protected Access 3* (WPA3), que utiliza um mecanismo para proteger a troca inicial de chaves e impede ataques de dicionário *offline*, proporcionando um nível de segurança significativamente maior.

Referências

[1] Daniel E. Capano. *Wireless security: IEEE 802.11 and CCMP/AES*. URL: https://www.controleng.com/wireless-security-ieee-802-11-and-ccmp-aes/ (acedido em 14/05/2026).

[2] Computer Hope. *TKIP*. URL: https://www.computerhope.com/jargon/t/tkip.htm (acedido em 15/05/2026).

[3] Keystrokes. *WPA/ WPA2 Dictionary Attack Explained*. URL: https://keystrokes2016.wordpress.com/2016/02/09/wpa-wpa2-dictionary-attack-explained/ (acedido em 17/05/2026).

[4] Mahesh kumar. *Four-Way Handshake*. URL: https://medium.com/wifi-testing/four-way-handshake-32356fbec1b5 (acedido em 17/05/2026).

[5] Ana Marques Lucas Braga. *O que é WEP, WPA, WPA2 e WPA3? Veja as diferenças entre as chaves de segurança*. URL: https://tecnoblog.net/responde/o-que-e-wep-wpa-wpa2-wpa3-diferencas-protocolo-seguranca-wi-fi/ (acedido em 12/05/2026).

[6] Professor Messer. *TKIP and CCMP – CompTIA Security+ SY0-401: 1.5*. URL: https://www.professormesser.com/security-plus/sy0-401/tkip-and-ccmp/ (acedido em 14/05/2026).

[7] Rene Molenaar. *WPA and WPA2 4-Way Handshake*. URL: https://networklessons.com/wireless/wpa-and-wpa2-4-way-handshake (acedido em 16/05/2026).

[8] Rodrigo R. Paim. *WEP, WPA e EAP*. URL: https://www.gta.ufrj.br/ensino/eel879/trabalhos_vf_2011_2/rodrigo_paim/wpa.html (acedido em 16/05/2026).

[9] Andrei Popov. *Prohibiting RC4 Cipher Suites*. URL: https://datatracker.ietf.org/doc/rfc7465/ (acedido em 16/05/2026).

[10] TechTarget. *Wireless security: Differences between WEP, WPA, WPA2, WPA3*. URL: https://www.techtarget.com/searchnetworking/feature/Wireless-encryption-basics-Understanding-WEP-WPA-and-WPA2 (acedido em 13/05/2026).

[11] Wikipédia. *Comunicações sem fio*. URL: https://pt.wikipedia.org/wiki/Comunica%C3%A7%C3%B5es_sem_fio (acedido em 08/05/2026).

[12] Wikipédia. *História da Internet*. URL: https://pt.wikipedia.org/wiki/Hist%C3%B3ria_da_Internet (acedido em 08/05/2026).



Instituto Superior
de Engenharia
Politécnico de Coimbra